



Lumi Reading · Security & Privacy Evidence

S1 / S3 / S5

TLS & Cryptography Profile

Lumi Education Pty Ltd · ABN 45 700 349 015 · 24 July 2026

FINAL · 2026-07-24

Document: ST4S evidence for S1 (encryption in transit), S3 (encryption on upload), S5 (proper TLS certificates); the "crypto profile" from the remediation plan Phase 3. **Version:** 1.0 · **Date:** 24 July 2026 **Method:** Wave 3 of the self-managed assessment — a **strictly passive, read-only** TLS + security-header scan (OpenSSL 3.6.2 handshakes + HTTP HEAD), authorised by the Security Lead for the listed Lumi-owned hostnames. No exploitation, authentication, writes, or load. No secrets or personal data are involved.

1. Scan results (per endpoint)

Protocols: whether the server *accepts* a handshake at each TLS version. "Negotiated" is the default (preferred) protocol/cipher.

Endpoint	TLS 1.0	TLS 1.1	TLS 1.2	TLS 1.3	Negotiated	Cert issuer / key / sig	HSTS
<code>lumi-reading.com</code> (marketing)	x rejected	x rejected	✓	✓	TLS 1.3 · AES-128-GCM	Google Trust Services (WR3) · RSA-2048 · SHA-256 · exp 2026-10-08	<code>max-age=31556926</code> (no includeSubDomains/preload)
<code>lumi-school-admin-au.web.app</code> (school portal)	x	x	✓	✓	TLS 1.3 · AES-128-GCM	Google Trust Services (WR4) · RSA-2048 · SHA-256 · exp 2026-10-18	<code>max-age=31556926; includeSubDomains; preload</code>

Endpoint	TLS 1.0	TLS 1.1	TLS 1.2	TLS 1.3	Negotiated	Cert issuer / key / sig	HSTS
<code>lumi-dev-admin-au.web.app</code> (super-admin)	x	x	✓	✓	TLS 1.3 · AES-128-GCM	Google Trust Services (WR4) · RSA-2048 · SHA-256 · exp 2026-10-18	<code>...; includeSubDomains; preload</code>
<code>lumi-ninc-au.web.app</code> (default hosting)	x	x	✓	✓	TLS 1.3 · AES-128-GCM	Google Trust Services (WR4) · RSA-2048 · SHA-256 · exp 2026-10-18	<code>...; includeSubDomains; preload</code>
<code>lumi-marketing-au.web.app</code>	x	x	✓	✓	TLS 1.3 · AES-128-GCM	Google Trust Services (WR4) · RSA-2048 · SHA-256 · exp 2026-10-18	<code>...; includeSubDomains; preload</code>
<code>lumistatus.aged-morning-985b.workers.dev</code> (status worker, public banner only)	x	x	✓	✓	TLS 1.3 · AES-256-GCM	Let's Encrypt (YE1) · ECDSA P-256 · SHA-384 · exp 2026-08-27	(none)

Every endpoint carrying customer data enforces TLS 1.2+ only (TLS 1.0/1.1 handshakes are refused), negotiates TLS 1.3, and uses AEAD (AES-GCM) ciphers with a valid, in-date, publicly-trusted certificate.

2. Crypto profile (for the ST4S answers)

- **In transit (S1/S3): TLS 1.2 or above only** — verified by scan (1.0/1.1 rejected; 1.3 negotiated). AEAD ciphers only (AES-128/256-GCM).
- **Certificates (S5):** publicly-trusted CAs (Google Trust Services; Let's Encrypt), RSA-2048/SHA-256 or ECDSA-P256/SHA-384 — modern, in-date, auto-renewed by the hosting platforms.
- **At rest:** AES-256, Google-managed for Firestore, Cloud Storage and backups (`australia-southeast1`) — per the vendor register and `AU_RESOURCE_LOCATION_AUDIT_2026-07-17.md` ; not scannable from outside, evidenced by Google's platform documentation.
- **Password hashing:** scrypt, managed by Firebase Authentication / Identity Platform — Firebase-documented; combined with the 14+/complexity policy now enforced (see A2).

Conclusion: S1, S3 and S5 can now truthfully take the strongest option — *"Encryption AES-128+ / Hashing SHA-256+ / TLS 1.2 or above only (Tier 1)."*

3. Minor hardening recommendations (non-blocking)

These do not affect the S1/S3/S5 answer; they are optional uplift.

1. `lumi-reading.com` **HSTS** lacks `includeSubDomains; preload` (the four `.web.app` sites have the full directive). Add them on the custom-domain HSTS config.
2. **Status worker** (`workers.dev`) sets no HSTS and no security headers. It serves only a public status banner (no personal data), so this is low-risk — optionally enable HSTS via Cloudflare, or move it behind a custom domain with min-TLS pinned (already TLS 1.2+ in practice).
3. **Portal response headers:** the root responses carry HSTS but not `Content-Security-Policy` , `X-Frame-Options` , or `X-Content-Type-Options` : **DONE for the portals (2026-07-24, PR #569):** `X-Content-Type-Options: nosniff` , `X-Frame-Options: SAMEORIGIN` , and `Referrer-Policy: strict-origin-when-cross-origin` added to school-admin-web + admin (deployed + verified live) and the marketing static-hosting config (`firebase.json`). A full `Content-Security-Policy` remains **deferred** (needs nonce-based Next middleware; risks breaking the app) — a separate deliberate task. Relates to S11 security configuration, not S1/S3/S5.

4. Scope & authorisation

Passive, read-only, authorised by the Security Lead (24 Jul 2026) as a narrow written exception for the six Lumi-owned hostnames above. The scan tests **Lumi's TLS configuration** of Firebase Hosting / Cloudflare, not the vendors' own infrastructure. Stop-on-anomaly was in force; no anomalies were encountered.

— End of profile —